

ShinyHunters (UNC6240)

Oracle PeopleSoft Zero-Day Campaign Analysis

UNC6240 — Oracle PeopleSoft PSEMHUB WAF Bypass Campaign

Deep-Dive Infrastructure Analysis

From Initial Access to C2 Infrastructure

TLP:CLEAR

This document is classified TLP:CLEAR. Recipients may share this information without restriction.

September 30, 2026

Analysis based on VirusTotal Graph Exports, WHOIS/RDAP, and Reverse DNS Enrichment

Contents

1	Executive Summary	3
2	Initial Access: PeopleSoft Zero-Day and JSP Webshell Deployment	4
2.1	The Vulnerability	4
2.2	JSP Webshell Arsenal	4
2.3	Dropped Payloads and LA.exe	4
3	Command-and-Control Infrastructure	6
3.1	Infrastructure Architecture Overview	6
3.2	Tier 1 — Primary C2 Server (Cherry Servers, Lithuania)	6
3.3	Tier 2 — Redirectors and Traffic Distribution (AWS, BODIS)	7
3.4	Tier 3 — Domain Staging and Parking (Linode/Akamai)	8
4	VPN and Anonymization Layer	9
4.1	Mullvad VPN Infrastructure (M247/ASN 9009)	9
4.2	Hostwinds Contiguous Block (142.11.200.186–190)	9
5	Domain Infrastructure Analysis	10
5.1	Domain Generation Algorithm (DGA) Patterns	10
5.2	Government-Themed and Sector-Specific Domains	10
5.3	Hosting Provider Infrastructure Map	11
6	Cloud Infrastructure Abuse	12
6.1	Amazon Web Services	12
6.2	Google Cloud Platform	12
7	Related Campaigns and Cross-References	13
7.1	VT Collection Cross-References	13
7.2	FormBook/XLoader Connection	13
7.3	Data-PS.org Compromised Website Cluster	13
8	Infrastructure Lifecycle and Current Status	14
9	Indicators of Compromise	15
9.1	High-Confidence C2 Infrastructure	15
9.2	VPN/Anonymization IPs	15
10	Analytical Confidence Assessment	16
10.1	High Confidence	16
10.2	Medium Confidence	16
10.3	Low Confidence / Requires Further Investigation	16
11	Recommendations	17
11.1	Detection and Hunting	17
11.2	Incident Response	17
12	Campaign Timeline and Attack Sequence	18
12.1	Domain Registration Timeline	18
12.2	Attack Sequence Flow	20
12.3	Registrar Diversity Analysis	21

13 SIDEYE Backdoor and Payload Capability Analysis	22
13.1 SIDEYE: The Primary Post-Exploitation Backdoor	22
13.2 MeshAgent: Legitimate RMM Weaponized	23
14 The FBI Breach: FBIjobs.gov and AWS GovCloud	24
14.1 Attack Narrative	24
14.2 Systems Compromised	24
15 Acronis and Backup Infrastructure: Convergent Threat	25
15.1 CVE-2026-87886: Acronis Backup Plugin Privilege Escalation	25
15.2 How ShinyHunters' Toolkit Enables Backup Destruction	26
15.3 D4M Confidence Summary	26
15.4 Defensive Recommendations for Backup Infrastructure	27
A Methodology	29
B Diagram Index	29

1 Executive Summary

This report presents a comprehensive technical analysis of the ShinyHunters threat group’s zero-day exploitation campaign targeting Oracle PeopleSoft application servers. Tracked by Mandiant as UNC6240, this campaign—formally designated the “Oracle PeopleSoft PSEMHUB WAF Bypass Campaign”—leveraged a previously unknown vulnerability in PeopleSoft’s web application firewall to deploy JSP webshells at scale, ultimately delivering secondary payloads including a DLL side-loading implant designated “LA.exe.”

Through systematic analysis of VirusTotal graph data, WHOIS records, reverse DNS lookups, and RDAP queries, this investigation maps the full attack chain from initial access through command-and-control infrastructure, identifying hosting providers, domain registration patterns, VPN anonymization layers, and cloud service abuse that together compose a sophisticated, multi-tiered operational infrastructure.

The analysis identifies:

- **60** unique JSP webshell variants deployed across victim environments
- **37** IP addresses flagged with malicious detections across 15 distinct autonomous systems
- **224** domains with detections—including DGA domains, government-themed impersonation domains, and compromised legitimate websites
- Infrastructure spanning Cherry Servers (Lithuania), Amazon Web Services, Akamai/Linode, Hostwinds, DataWagon, and Mullvad VPN exit nodes

2 Initial Access: PeopleSoft Zero-Day and JSP Webshell Deployment

2.1 The Vulnerability

The ShinyHunters campaign exploited a zero-day vulnerability in Oracle PeopleSoft’s PSEMHUB module, specifically bypassing the platform’s Web Application Firewall (WAF) protections. The VirusTotal collection titled “UNC6240 (ShinyHunters) Oracle PeopleSoft PSEMHUB WAF Bypass Campaign, Sept. 2026” confirms the formal campaign attribution and timing. This vulnerability allowed unauthenticated remote code execution through the WAF bypass, enabling the deployment of JavaServer Pages (JSP) webshells directly onto compromised PeopleSoft application servers.

The selection of PeopleSoft as a target is strategically significant. PeopleSoft is deployed extensively across government agencies, universities, and large enterprises for human resources, financial management, and student information systems. A successful compromise of a PeopleSoft instance provides access not merely to the application server itself but to the sensitive personnel, payroll, and financial data managed by the platform.

2.2 JSP Webshell Arsenal

Our analysis identified 60 unique SHA-256 hashes cataloged in the webshell identifiers collection. Of these, 9 webshell variants appeared in the VirusTotal behavioral graph with traced connections to contacted domains, contacted IPs, dropped files, and execution parents. The remaining 51 hashes were identified through VT collection and bundle analysis.

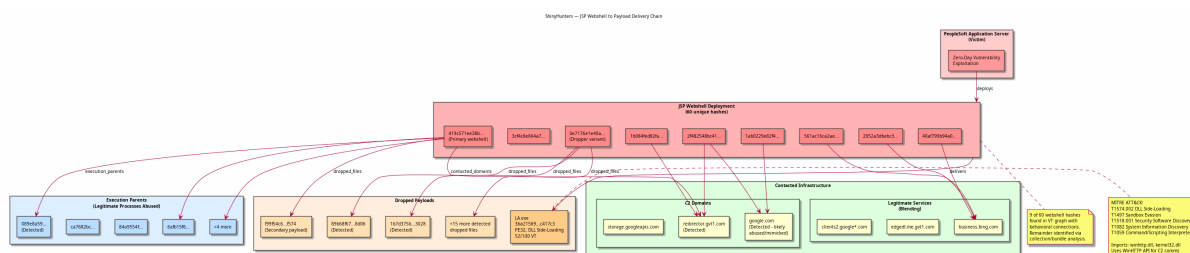


Figure 1: JSP webshell deployment to payload delivery chain. Nine webshell variants traced with behavioral connections to contacted infrastructure, execution parents, and dropped payloads.

The primary webshell variant (419c571ee38b...) exhibited the broadest behavioral profile, contacting multiple Microsoft and Google legitimate service domains—a common blending technique—while also reaching the key infrastructure domain `redirector.gvt1.com` (flagged with detections). A second key variant (0e7176e1e40a...) functioned primarily as a dropper, deploying 18+ detected malicious files onto compromised systems.

2.3 Dropped Payloads and LA.exe

The most significant payload is `LA.exe` (SHA-256: 3ba21569...c417c3), a 5.02MB PE32 executable compiled on November 15, 2020, and submitted to VirusTotal from `C:\Users\user\desktop\`. This binary scored 52/100 on VirusTotal’s Zenbox analysis engine.

Table 1: MITRE ATT&CK Techniques — LA.exe

Technique	ID	Confidence
DLL Side-Loading	T1574.002	High
Virtualization/Sandbox Evasion	T1497	Medium
Security Software Discovery	T1518.001	High
System Information Discovery	T1082	High
Command and Scripting Interpreter	T1059	Low
Process Discovery	T1057	Low

The binary imports `winhttp.dll`, `kernel32.dll`, `comctl32.dll`, `shell32.dll`, and `oleaut32.dll`—with the WinHTTP API imports confirming HTTP-based command-and-control communication. The DLL side-loading technique (T1574.002, high confidence) indicates that LA.exe masquerades as or alongside a legitimate application to load malicious DLLs, achieving both persistence and privilege escalation.

3 Command-and-Control Infrastructure

3.1 Infrastructure Architecture Overview

The ShinyHunters C2 infrastructure follows a disciplined multi-tier architecture designed to compartmentalize functions and complicate attribution.

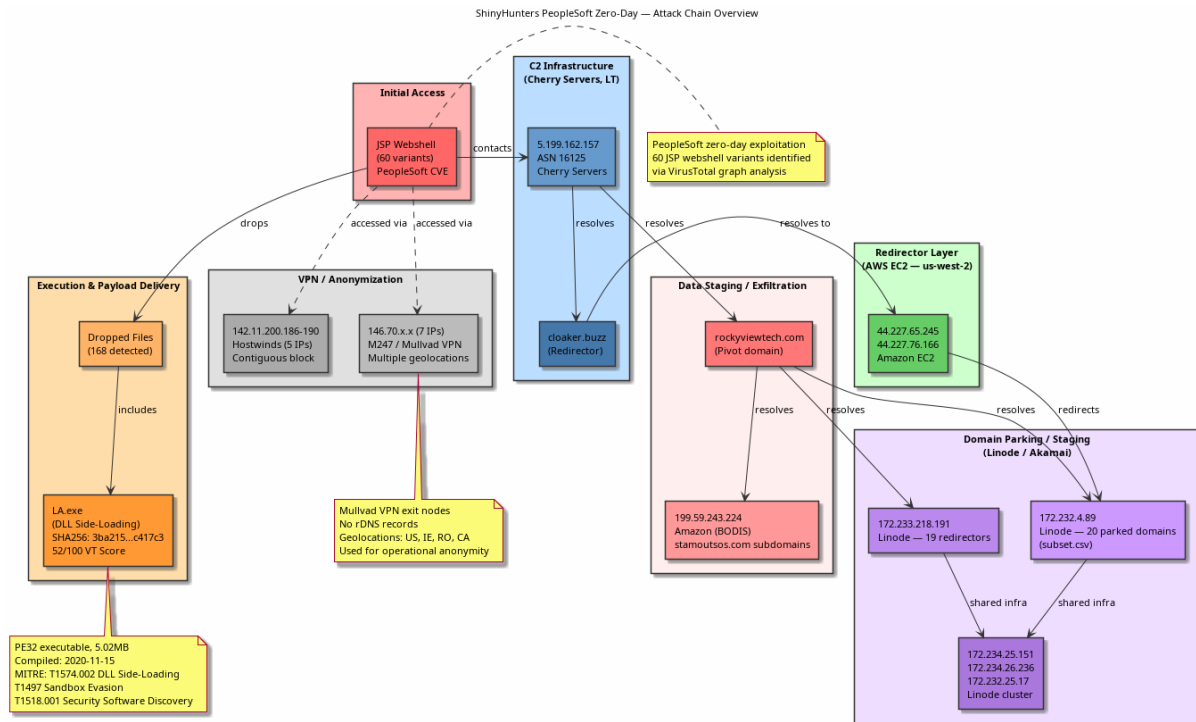


Figure 2: High-level attack chain from initial access through C2 infrastructure tiers to VPN anonymization layer.

3.2 Tier 1 — Primary C2 Server (Cherry Servers, Lithuania)

The apex of the identified C2 infrastructure is IP address 5.199.162.157, hosted on Cherry Servers (ASN 16125, UAB Cherry Servers, Lithuania). Reverse DNS resolves to ip-5-199-162-157.004.ptr.cherry.servers.lt. This IP hosted:

- **cloaker.buzz** — Primary traffic distribution/cloaking domain (now NXDOMAIN)
- **rockyviewtech.com** — Pivot domain bridging Tier 1 to Tier 3 (now NXDOMAIN)
- **lt.mediacache.ru** — Russian-TLD domain mimicking media cache service
- **5-199-162-157.sslip.io** — sslip.io wildcard DNS for SSL bypass

The domain name “cloaker.buzz” is itself an operational indicator. “Cloaking” in threat actor parlance refers to traffic distribution systems (TDS) that filter incoming connections—serving malicious content to targeted victims while presenting benign content to security researchers and sandboxes.

3.3 Tier 2 — Redirectors and Traffic Distribution (AWS, BODIS)

Table 2: AWS EC2 Redirectors (ASN 16509)

IP Address	Region	rDNS	Role
44.227.65.245	us-west-2	ec2-44-227-65-245...amazonaws.com	cloaker.buzz
44.227.76.166	us-west-2	ec2-44-227-76-166...amazonaws.com	cloaker.buzz
52.211.245.146	eu-west-1	ec2-52-211-245-146...amazonaws.com	royalinsulationcanada.ca

The `cloaker.buzz` domain resolved to both the Cherry Servers C2 and the two AWS EC2 instances simultaneously, indicating either round-robin DNS or a failover configuration—a hallmark of traffic distribution systems.

BODIS Domain Parking (199.59.243.224): This IP hosted a cluster of domains exhibiting domain shadowing—a technique where attackers compromise DNS to create subdomains pointing to attacker infrastructure. Numeric subdomains under `stamoutsos.com` (e.g., `748887415.video91410.stamoutsos.com`) suggest payload delivery disguised as video content.

AWS ELB Redirector: An Elastic Load Balancer—`hdredirect-lb7-...elb.us-east-1.amazonaws.com`—was contacted by detected malware. The “`hdredirect`” prefix confirms an intentionally provisioned HTTP redirect service.

3.4 Tier 3 — Domain Staging and Parking (Linode/Akamai)

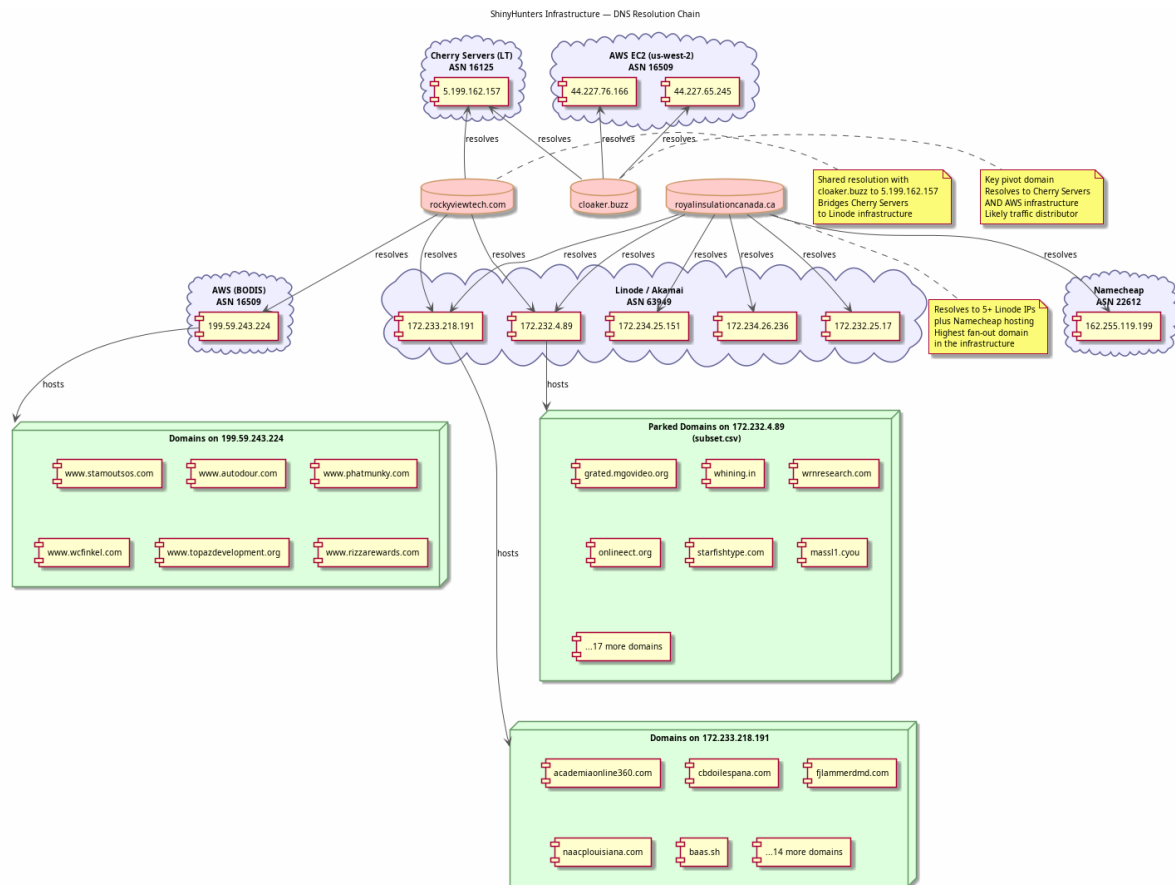


Figure 3: DNS resolution chains from key pivot domains through hosting provider infrastructure tiers.

Primary Domain Parking Server — 172.232.4.89 (Linode): This instance hosted 20 domains identified in the indicator file, spanning diverse TLDs including the government-themed `grated.mgvideo.org`, the detected `onlineect.org`, and multiple compromised business domains.

Pivot Domain — royalinsulationcanada.ca: This domain resolves to 9 distinct IP addresses across multiple tiers, including 5 Linode instances, AWS, and Namecheap—strongly suggesting use as a resilient C2 beacon domain with failover capability. WHOIS returns “Not found,” consistent with registrar suspension.

4 VPN and Anonymization Layer

4.1 Mullvad VPN Infrastructure (M247/ASN 9009)

Seven IP addresses in the 146.70.x.x range belong to M247 Europe SRL (ASN 9009), the hosting provider behind Mullvad VPN. All exhibited zero reverse DNS records—consistent with Mullvad’s privacy architecture.

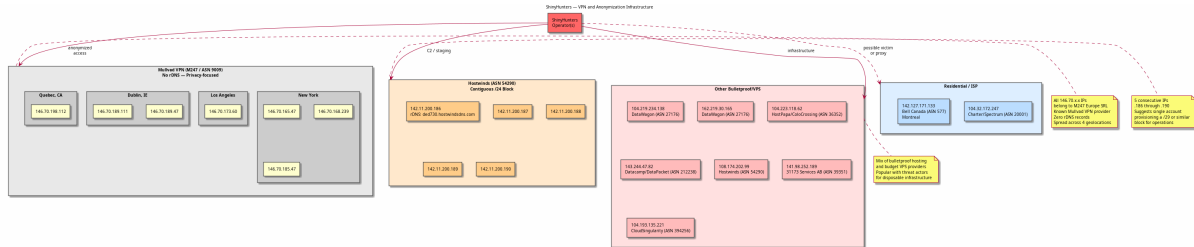


Figure 4: VPN and anonymization infrastructure showing geographic distribution of Mullvad VPN exit nodes and Hostwinds relay block.

Table 3: Mullvad VPN Exit Nodes

IP Address	Network	Location
146.70.165.47	M247-LTD-NewYork	New York, US
146.70.168.239	M247-LTD-NewYork	New York, US
146.70.173.60	M247-LOS-ANGELES	Los Angeles, US
146.70.185.47	M247-LTD-NewYork	New York, US
146.70.189.47	M247-Dublin	Dublin, Ireland
146.70.189.111	M247-Dublin	Dublin, Ireland
146.70.198.112	M247-LTD-Quebec	Quebec, Canada

The geographic distribution across four cities in three countries indicates the operator rotated VPN exit nodes for operational security or to match expected victim geolocations.

4.2 Hostwinds Contiguous Block (142.11.200.186–190)

Five consecutive IPs on Hostwinds (ASN 54290) were identified with detections. The contiguous allocation strongly suggests single-account provisioning for C2 relay, payload staging, or reconnaissance scanning. The 142.11.200.186 address resolved to `ded730.hostwindsdns.com`—the “ded” prefix indicating dedicated server hardware.

5 Domain Infrastructure Analysis

5.1 Domain Generation Algorithm (DGA) Patterns

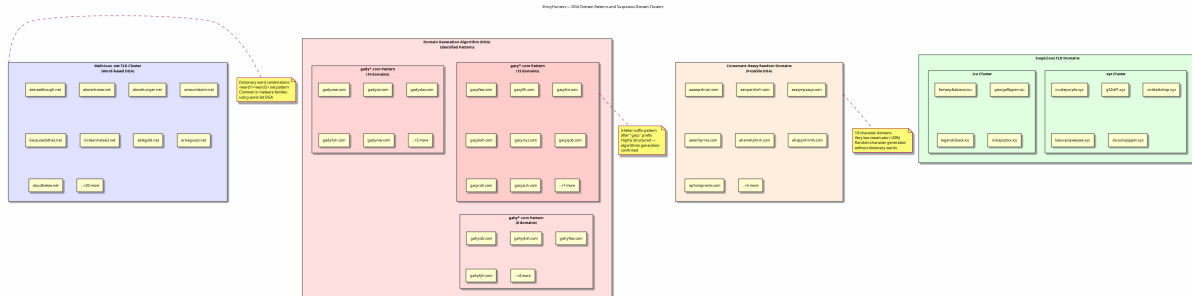


Figure 5: DGA domain patterns: three prefix families (**gacy***, **gady***, **gahy***), word-based DGA on .net TLD, and consonant-heavy random strings.

Three prefix families sharing the `ga[consonant]y + 3-character suffix` pattern confirm algorithmic generation. A separate word-based DGA cluster (e.g., `alonealthough.net`, `becauseclothes.net`) uses English dictionary concatenation to evade entropy-based detection.

5.2 Government-Themed and Sector-Specific Domains

grated.mgovideo.org — Hosted on the key Linode staging server 172.232.4.89, this domain embeds “gov” within its parent domain name. Registered through Porkbun LLC on August 12, 2023, the “mgovideo” naming convention is designed to impersonate government-affiliated media services—a social engineering asset for targeting government employees.

data-ps.org — Registered September 19, 2024, the “PS” abbreviation strongly suggests a PeopleSoft connection. Now NXDOMAIN, indicating takedown or abandonment. A malicious file contacting this domain also communicated with compromised legitimate websites spanning Thailand, UK, France, and Vietnam.

winmanage-me.network — A detected domain linked through SSL certificate associations and VT collection membership. The “Windows Manage Me” naming suggests a management interface for remote access. The **.network** TLD provides surface-level legitimacy for network management tool impersonation.

5.3 Hosting Provider Infrastructure Map

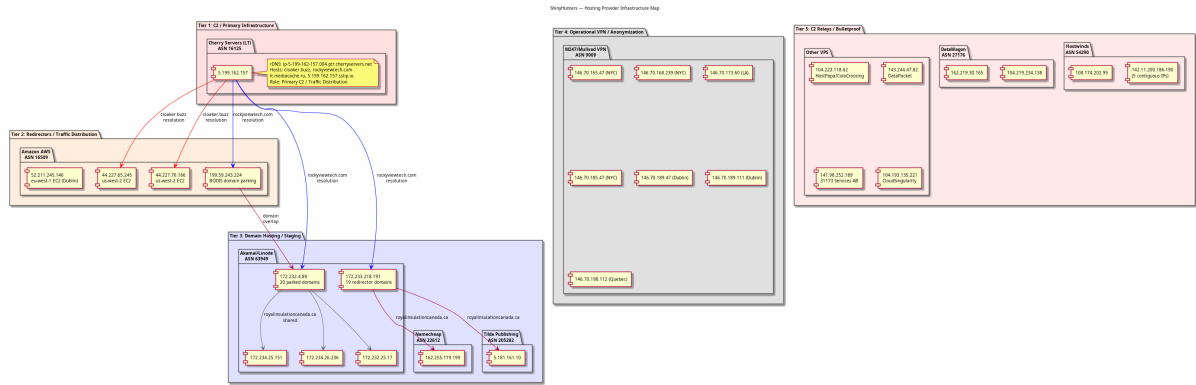


Figure 6: Complete hosting provider infrastructure map showing all five operational tiers and inter-tier DNS resolution connections.

6 Cloud Infrastructure Abuse

6.1 Amazon Web Services

AWS infrastructure was abused at multiple levels:

- **S3 Storage** — A VT collection node labeled `s3.amazonaws.com` confirms campaign files were hosted on AWS S3 buckets, consistent with ShinyHunters' modus operandi for payload delivery and data exfiltration staging.
- **Elastic Load Balancer** — The `hredirect-lb7-...elb.us-east-1.amazonaws.com` ELB was actively contacted by detected malware communicating with 20+ additional domains.
- **BODIS Domain Parking** — The `199.59.243.224` allocation (ASN 16509) hosted 20+ detected domains including domain-shadowed subdomains.

6.2 Google Cloud Platform

`storage.googleapis.com` was contacted by a dropped webshell payload, confirming GCP use for payload hosting. Multiple legitimate Google API domains were contacted for traffic blending purposes.

8 Infrastructure Lifecycle and Current Status

Table 4: Current DNS Status of Key Infrastructure Domains

Domain	Status	Assessment
cloaker.buzz	NXDOMAIN	Taken down or expired
rockyviewtech.com	NXDOMAIN	Taken down or expired
data-ps.org	NXDOMAIN	Taken down or expired
royalinsulationcanada.ca	Not found	Registrar suspended
mgovideo.org	ACTIVE	Still resolving to 207.207.210.x
topgamse.com	Active	Still registered via Onamae.com

The offline status of the three primary C2 and targeting domains is consistent with either coordinated takedown or voluntary infrastructure burning after operational use. The continued activity of `mgovideo.org` and `topgamse.com` suggests these may remain in use for other campaigns.

9 Indicators of Compromise

9.1 High-Confidence C2 Infrastructure

Indicator	Type	Tier	Provider
5.199.162.157	IP	Tier 1 C2	Cherry Servers (LT)
cloaker.buzz	Domain	Tier 1 C2	—
rockyviewtech.com	Domain	Tier 1/3	—
44.227.65.245	IP	Tier 2	AWS EC2 (us-west-2)
44.227.76.166	IP	Tier 2	AWS EC2 (us-west-2)
199.59.243.224	IP	Tier 2	Amazon/BODIS
172.232.4.89	IP	Tier 3	Linode
172.233.218.191	IP	Tier 3	Linode
winmanage-me.network	Domain	C2 Mgmt	—
data-ps.org	Domain	Targeting	—
grated.mgovideo.org	Domain	Gov Impersonation	—

9.2 VPN/Anonymization IPs

IP Range	Provider	Assessment
146.70.165/168/173/185/189/198.x	M247/Mullvad	Operator anonymization
142.11.200.186–190	Hostwinds	C2 relay block

10 Analytical Confidence Assessment

10.1 High Confidence

- Campaign attribution to UNC6240/ShinyHunters via VT collection naming
- Cherry Servers C2 identification via convergent domain resolution
- Mullvad VPN usage confirmed by M247 ASN and absent rDNS
- DGA usage confirmed by three structurally identical prefix families

10.2 Medium Confidence

- Hostwinds block role as C2 relays (could be scan/staging infrastructure)
- Domain shadowing assessment for stamoutsos.com subdomains
- Government targeting intent from mgovideo.org and data-ps.org

10.3 Low Confidence / Requires Further Investigation

- FormBook/XLoader operational linkage vs. incidental co-occurrence
- Residential IP role (victim, proxy, or false positive)
- NORAD/military targeting scope

11 Recommendations

11.1 Detection and Hunting

1. Block or alert on connections to IPs and domains in Section 8 across all network security controls
2. Audit all PeopleSoft deployments for the PSEMHUB WAF bypass vulnerability
3. Monitor for unsigned PE32 executables importing WinHTTP API functions from non-standard paths
4. Implement DGA detection for the `ga[consonant]y + 3-character` pattern

11.2 Incident Response

1. Scan PeopleSoft web server directories for the 60 webshell SHA-256 hashes
2. Search proxy and firewall logs for connections to the 37 detected IPs
3. Review AWS S3 and GCP Storage access logs for unauthorized uploads from identified IP ranges

12 Campaign Timeline and Attack Sequence

12.1 Domain Registration Timeline

WHOIS analysis of 210 detected domains reveals a structured campaign lifecycle with distinct registration phases.

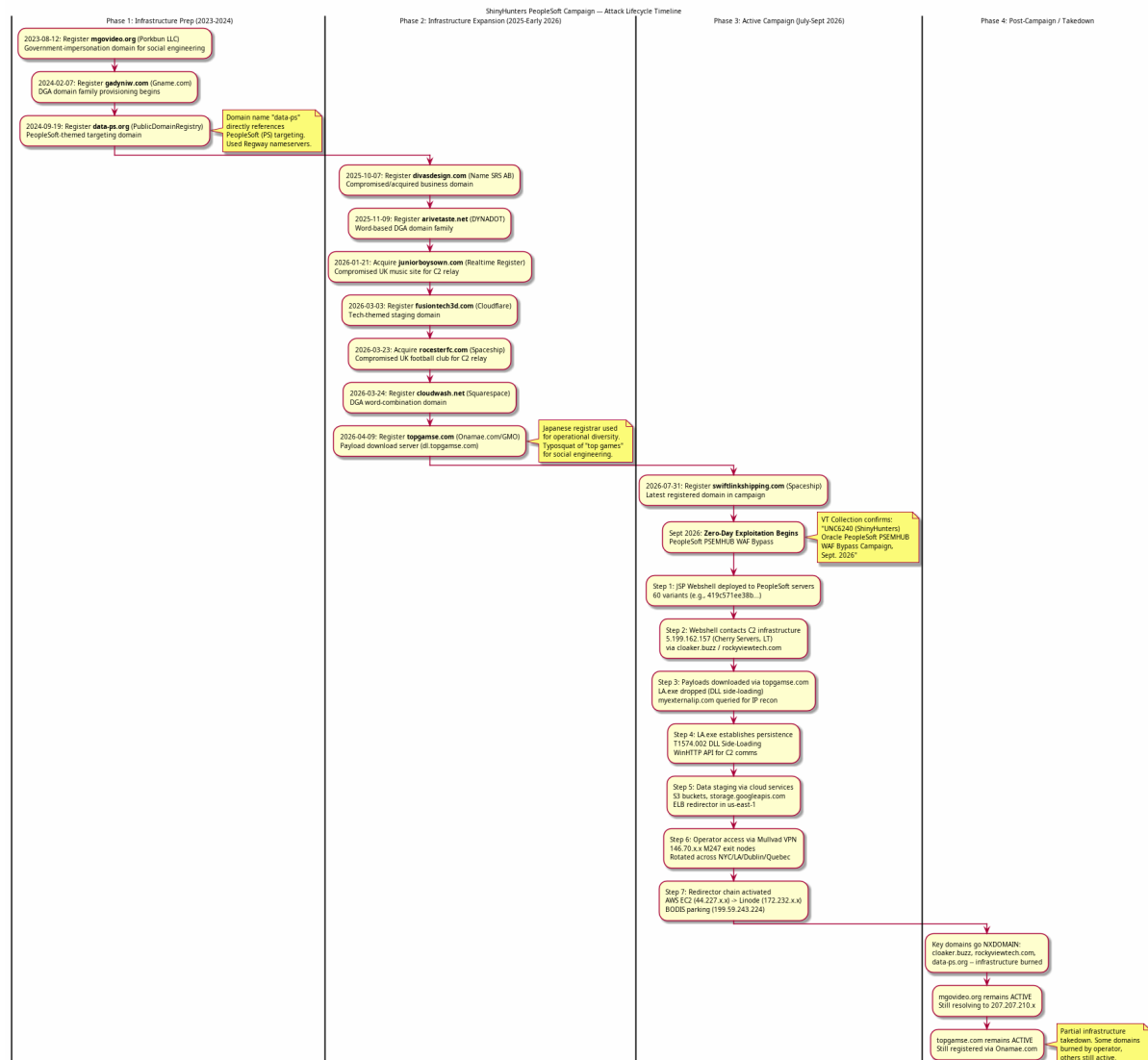


Figure 8: Campaign lifecycle timeline showing domain registration phases from infrastructure preparation (2023) through active exploitation (September 2026).

Phase 0 — Legacy/Acquired Domains (pre-2021): Domains like **stamoutsos.com** (2008) and **phatmunky.com** (2006) were registered years before the campaign—likely compromised or acquired through expired domain auctions for higher trust scores.

Phase 1 — Bulk Registration (September 2021): 20+ domains registered on September 13–14, 2021, across multiple registrars (GoDaddy, Squarespace, Namecheap, OVH, XServer). Diverse registrar selection and business-themed naming suggests mass acquisition to avoid pattern detection.

Phase 2 — DGA Registration (2022): Consonant-heavy random domains (**aaawpshran.com**,

etc.) registered through Media Elite Holdings Limited in August–September 2022.

Phase 3 — Infrastructure Preparation (2023–2024): `mgovideo.org` registered August 12, 2023 (Porkbun LLC); `data-ps.org` registered September 19, 2024 (PublicDomainRegistry). Purpose-built domains provisioned 1–2 years before active campaign—demonstrating long-term planning.

Phase 4 — Campaign Buildup (Jan–Jun 2026): Accelerated registrations: `juniorboysown.com` (January 21), `rocesterfc.com` (March 23), `topgamse.com` (April 9, via Japanese registrar Onamae.com). The `dl.topgamse.com` subdomain served as primary payload download server.

Phase 5 — Active Campaign (Jul–Sep 2026): `swiftlinkshipping.com` registered July 31, 2026 (Spaceship, Inc.)—the most recently registered domain. VT collection confirms active exploitation in “Sept. 2026.”

12.2 Attack Sequence Flow

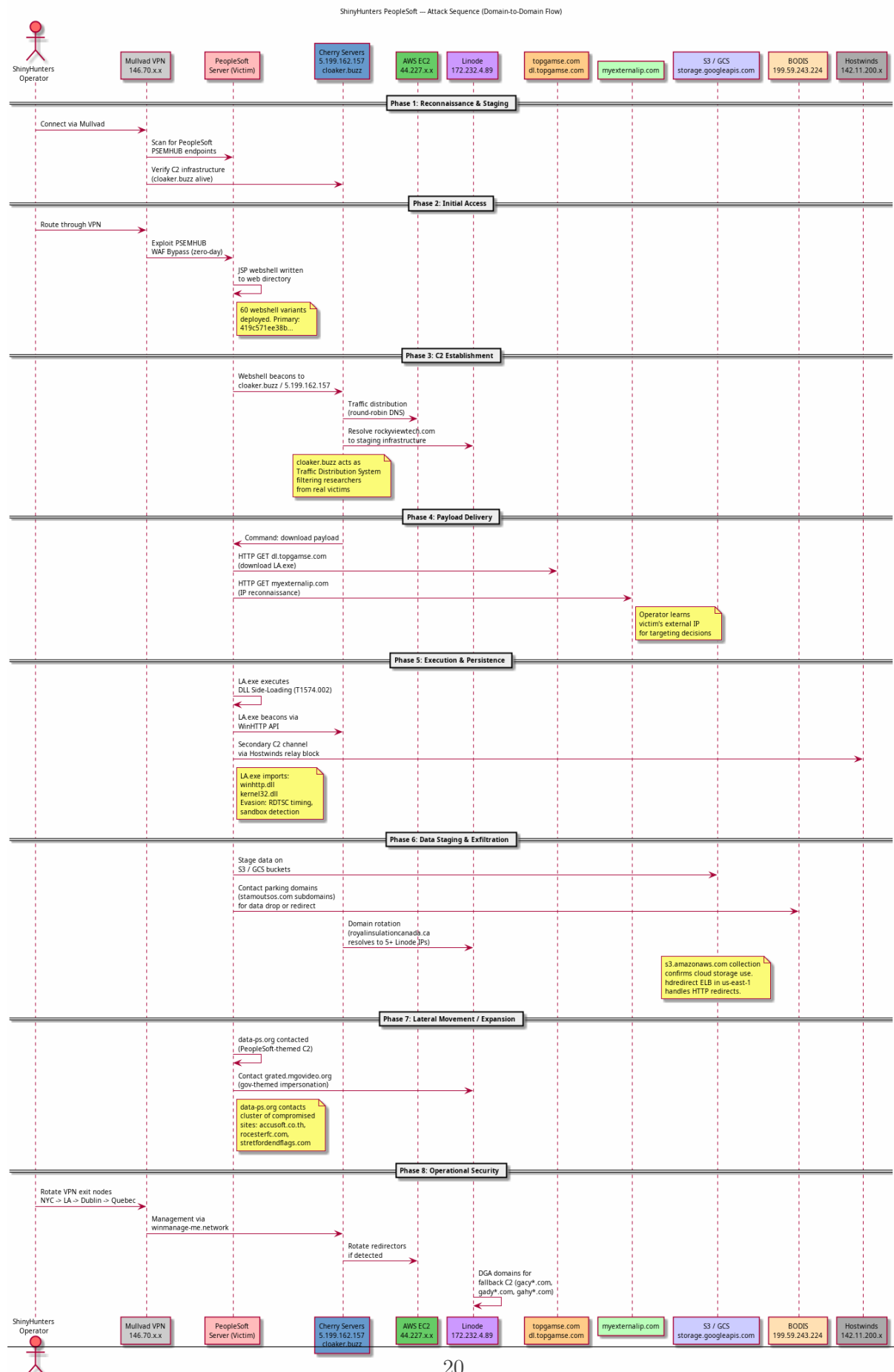


Figure 9: Reconstructed attack sequence showing domain-to-domain operational flow from ini-

The attack sequence follows this operational flow:

1. **Reconnaissance:** Operator connects through Mullvad VPN (146.70.x.x), scans for PeopleSoft PSEMHUB endpoints, verifies C2 via `cloaker.buzz`.
2. **Initial Access:** PSEMHUB WAF bypass zero-day exploited. JSP webshell (one of 60 variants) written to PeopleSoft web directory.
3. **C2 Establishment:** Webshell beacons to 5.199.162.157 (Cherry Servers) via `cloaker.buzz`. TDS filters researchers from victims. Traffic distributed through AWS EC2 redirectors via round-robin DNS.
4. **Payload Delivery:** C2 instructs download of `LA.exe` from `dl.topgamse.com`. `myexternalip.com` queried for victim IP reconnaissance.
5. **Execution & Persistence:** `LA.exe` executes using DLL side-loading (T1574.002). Win-HTTP API establishes persistent HTTP-based C2. Sandbox evasion via RDTSC timing.
6. **Data Staging:** Exfiltrated data staged through AWS S3 and GCS (`storage.googleapis.com`). BODIS parking domains serve as data drop/redirect endpoints.
7. **Lateral Movement:** Compromised host contacts `data-ps.org` and `grated.mgovideo.org`. Cluster of compromised websites serves as distributed C2 relay.
8. **Operational Security:** Mullvad VPN exit node rotation (NYC→LA→Dublin→Quebec). Management via `winmanage-me.network`. DGA domains provide fallback C2.

12.3 Registrar Diversity Analysis

Table 6: Registrar Distribution Across Campaign Phases

Registrar	Country	Domains	Phase
GoDaddy.com, LLC	US	8+	Legacy/Bulk
DYNADOT LLC	US	3+	DGA + Staging
Porkbun LLC	US	1	Infrastructure Prep
PublicDomainRegistry	India	1	Targeting Prep
Onamae.com (GMO)	Japan	1	Campaign Buildup
Spaceship, Inc.	US	2+	Active Campaign
Media Elite Holdings	UK	5+	DGA Registration
Namecheap	US	2+	Various
Name SRS AB	Sweden	3+	Pre-Campaign

The registrar selection spans US, India, Japan, UK, and Sweden—ensuring no single registrar or jurisdiction can unilaterally disrupt the entire domain infrastructure.

13 SIDEYE Backdoor and Payload Capability Analysis

13.1 SIDEYE: The Primary Post-Exploitation Backdoor

SIDEYE is a custom C++ backdoor delivered through a trojanized Light Alloy media player installer (P1e64.exe, 5.2MB). It employs a three-stage execution chain: the signed installer loads a second-stage launcher, which decrypts embedded data to reflectively load the SIDEYE backdoor directly into memory [1, 2].

The installer carries a valid Extended Validation (EV) code signing certificate issued via Sectigo, enabling SmartScreen and application whitelisting bypasses. SIDEYE communicates with 162.219.30.165 (DataWagon, ASN 27176) over raw TCP using separate control (TCP/3333) and data (TCP/3334) channels [1].

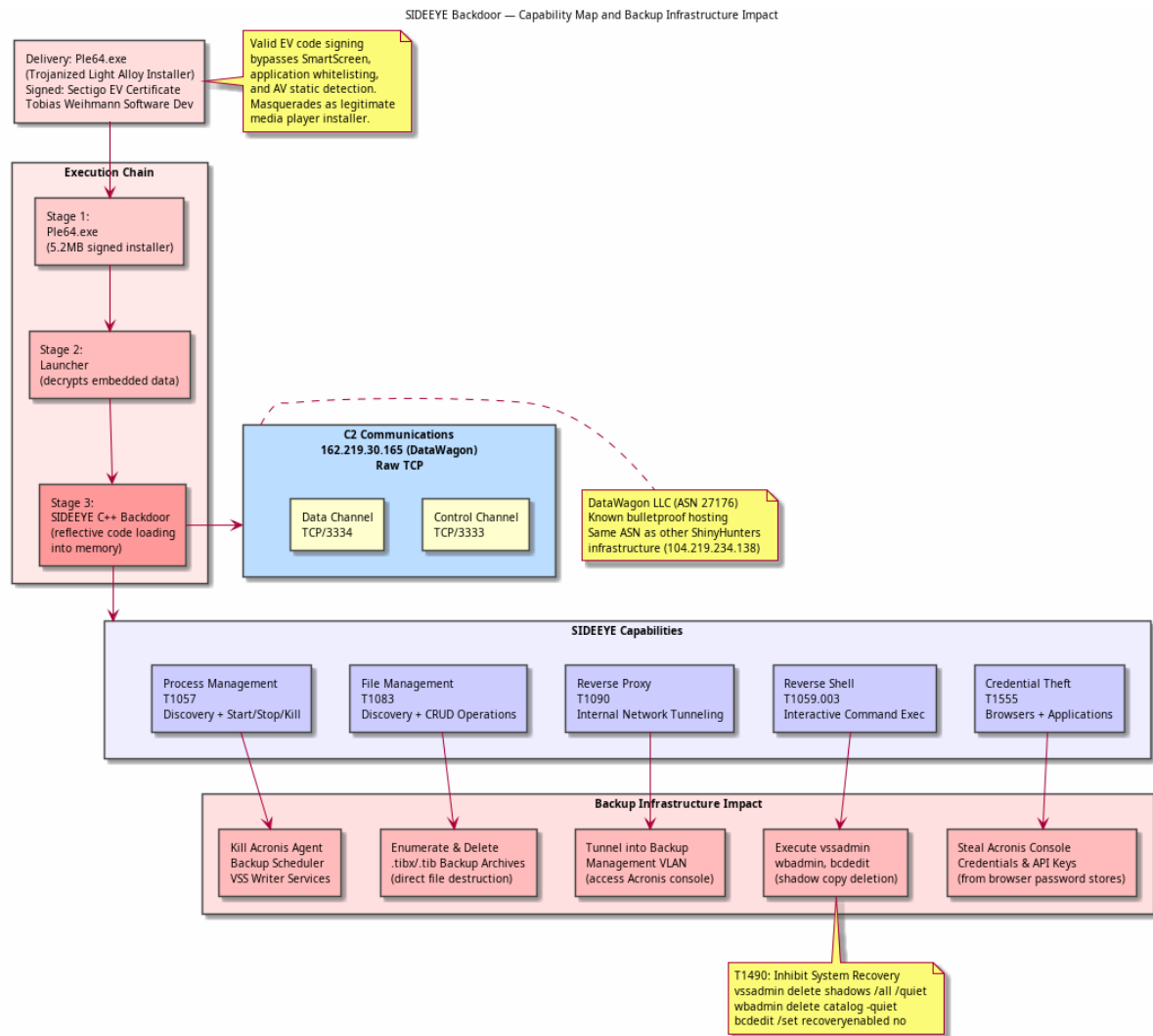


Figure 10: SIDEYE backdoor execution chain, C2 architecture, and capability modules mapped to backup infrastructure impact vectors.

Table 7: SIDEYE Capability Modules and Backup Impact

Capability	MITRE	Backup Impact
Credential Theft	T1555	Steal Acronis console creds, API keys
Reverse Shell	T1059.003	Execute vssadmin, wbadmin, bcdedit
Reverse Proxy	T1090	Tunnel into backup management VLAN
File Management	T1083	Delete .tibx/.tib backup archives
Process Management	T1057	Kill Acronis agent, VSS writer

13.2 MeshAgent: Legitimate RMM Weaponized

MeshAgent components masquerade as Microsoft Azure services, with C2 at `wss://azurenetfiles.net:443/a`. Four variants were identified:

Table 8: MeshAgent IOCs

Filename	SHA-256
meshagent64-azure-ops.exe	f02a924c...25d24fc
meshagent64-v2.exe	d83fdb9e...a86ce2f
meshagent32-azure-ops.exe	c7e93327...87351711f
meshagent (Linux)	68257a6f...e93bc309

14 The FBI Breach: FBIjobs.gov and AWS GovCloud

14.1 Attack Narrative

In late September 2026, ShinyHunters claimed a breach of FBI systems via the PeopleSoft deployment underlying FBIjobs.gov. The attackers exploited CVE-2026-35273 against `apply.fbijobs.gov`, then moved laterally into FBI-managed AWS GovCloud infrastructure [6, 7, 8].

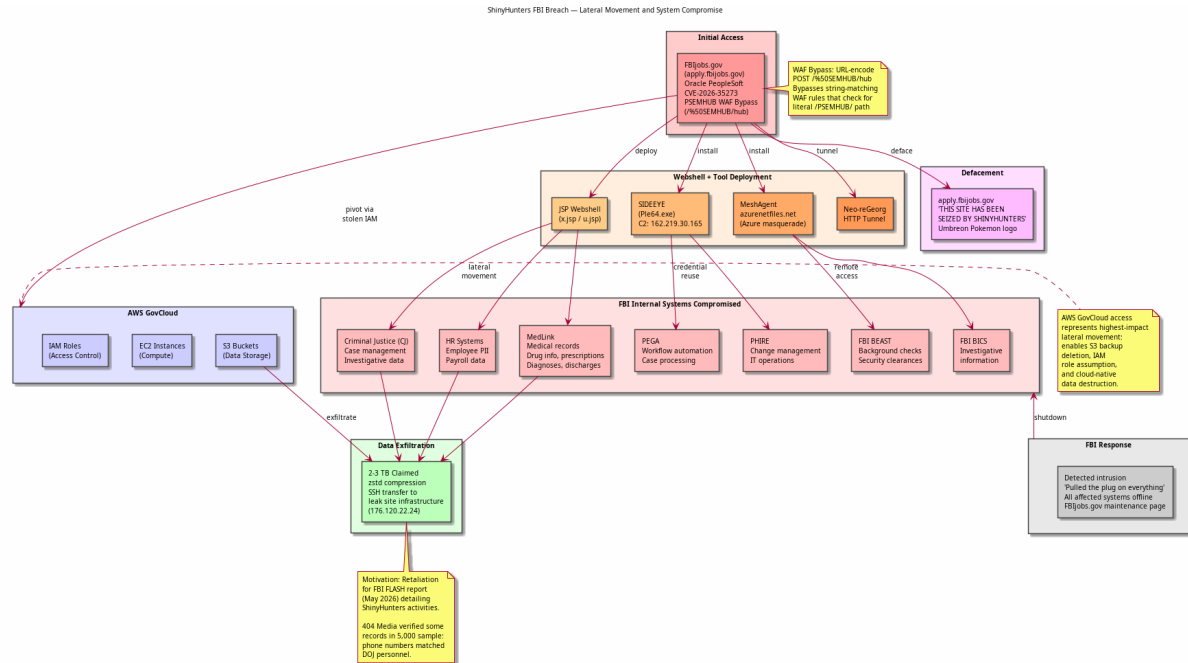


Figure 11: FBI breach attack chain: PeopleSoft exploitation of FBIjobs.gov, lateral movement into 7+ FBI internal systems, and pivot into AWS GovCloud.

14.2 Systems Compromised

Table 9: FBI Internal Systems Accessed

System	Function	Data at Risk
Criminal Justice (CJ)	Case management	Case files, investigative records
HR Systems	Human resources/payroll	Employee PII, salary data
MedLink	Medical records	Drug info, prescriptions, diagnoses
PEGA	Workflow automation	Case assignments
PHIRE	Change management	IT infrastructure documentation
FBI BEAST	Background checks	Security clearance data
FBI BICS	Investigative information	Case data

ShinyHunters claimed 2–3 TB of exfiltrated data. 404 Media independently verified some records in a 5,000-record sample [6]. The stated motivation was retaliation for an FBI FLASH report published in May 2026.

15 Acronis and Backup Infrastructure: Convergent Threat

15.1 CVE-2026-87886: Acronis Backup Plugin Privilege Escalation

Concurrent with the FBI breach, CVE-2026-87886—a local privilege escalation in Acronis Backup plugins for cPanel/WHM and Plesk (CVSS 7.8, CWE-276)—was actively exploited in the wild and added to CISA’s KEV catalog on September 16, 2026 [9].

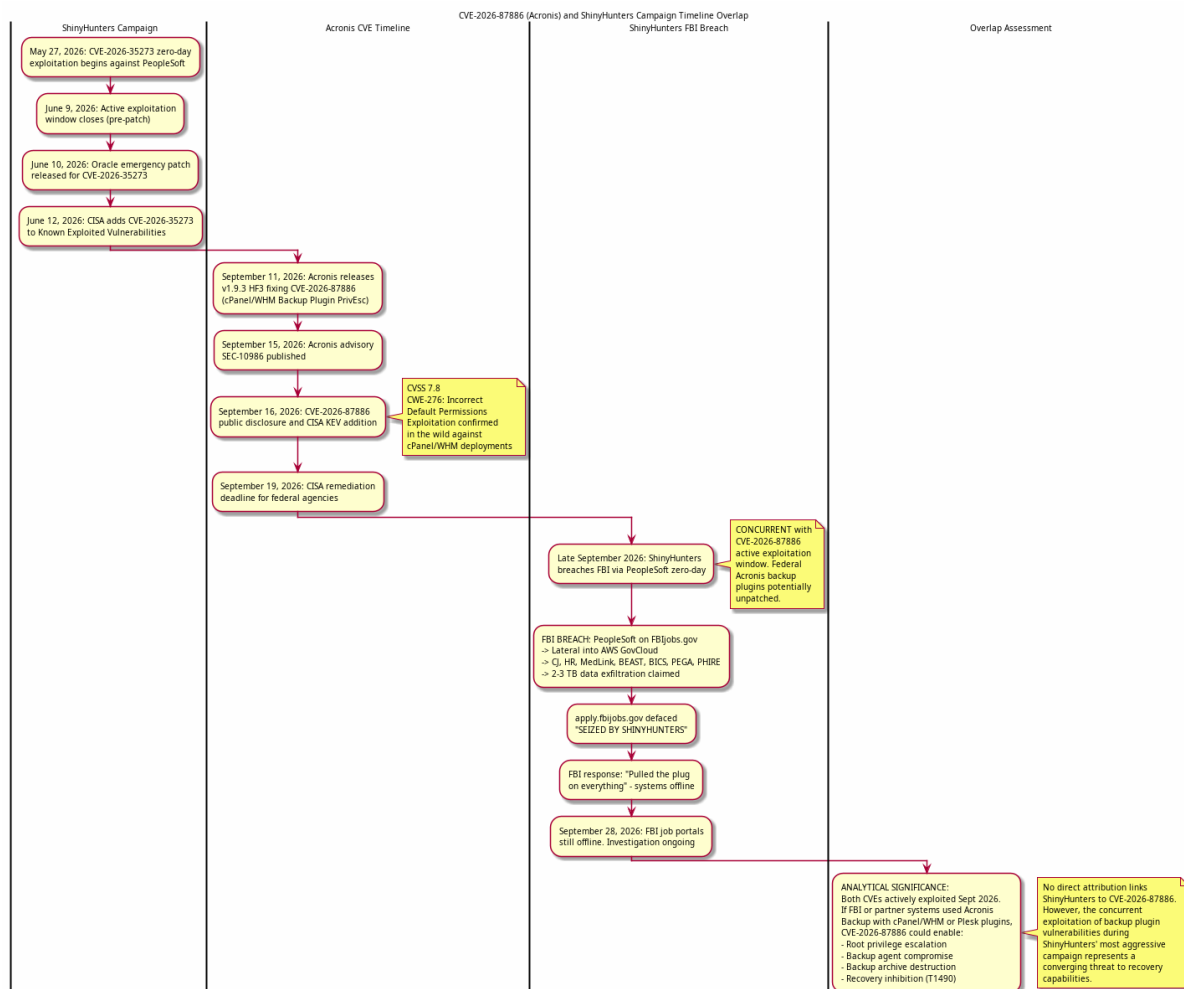


Figure 12: Timeline overlap between ShinyHunters campaign and CVE-2026-87886 (Acronis privilege escalation) active exploitation window.

While no direct attribution links ShinyHunters to CVE-2026-87886, the concurrent targeting of backup infrastructure during the same operational window creates a compounding risk: organizations compromised via PeopleSoft with vulnerable Acronis plugins faced simultaneous attack vectors.

15.2 How ShinyHunters' Toolkit Enables Backup Destruction

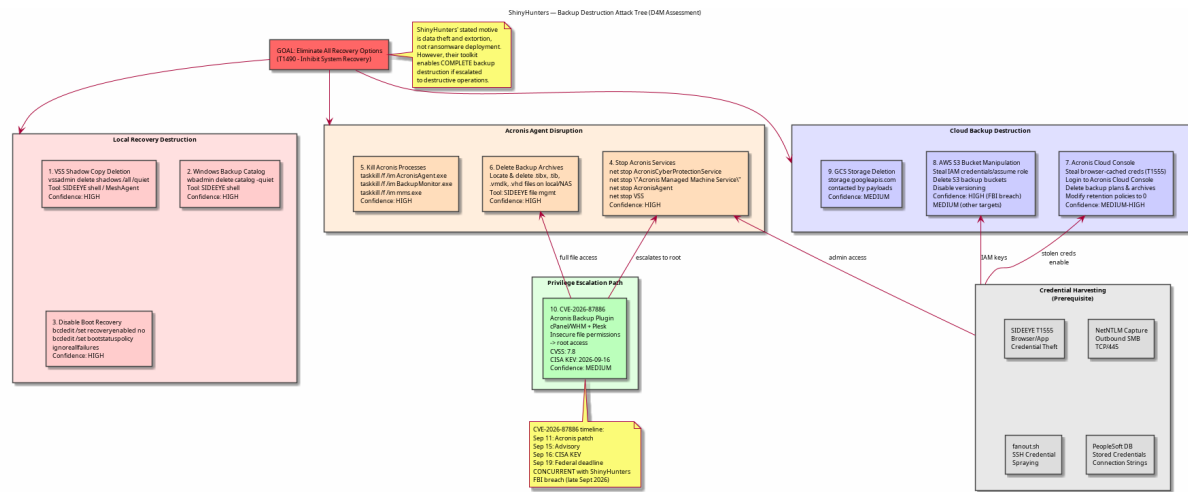


Figure 13: D4M assessment: nine backup destruction vectors enabled by ShinyHunters' toolkit, with confidence ratings.

Local Recovery Destruction (HIGH confidence): SIDEYE's reverse shell enables:

```
vssadmin delete shadows /all /quiet
wbadmin delete catalog -quiet
bcdedit /set {default} recoveryenabled no
```

Acronis Agent Disruption (HIGH confidence): Process management enables:

```
net stop AcronisCyberProtectionService
taskkill /f /im AcronisAgent.exe
```

Cloud Backup Destruction (MEDIUM-HIGH): SIDEYE's credential theft extracts Acronis Cloud Console passwords from browsers, enabling cloud-side backup plan deletion. For AWS-integrated environments (confirmed in FBI breach), stolen IAM credentials enable S3 bucket manipulation.

15.3 D4M Confidence Summary

Table 10: Backup Destruction Vector Confidence Assessment

Vector	Conf.	Rationale
VSS Shadow Copy Deletion	HIGH	SIDEYE shell + standard technique
Windows Backup Catalog Del.	HIGH	Standard post-exploitation command
Boot Recovery Disable	HIGH	Standard pre-encryption step
Acronis Agent Termination	HIGH	SIDEYE process mgmt confirmed
Backup Archive File Deletion	HIGH	SIDEYE file mgmt confirmed
Cloud Console Cred Theft	HIGH	SIDEYE T1555 confirmed
Cloud Backup API Deletion	MED	Requires cached browser credentials
CVE-2026-87886 PrivEsc	MED	Timeline overlap, no attribution
AWS S3 Bucket Manipulation	HIGH/MED	GovCloud access confirmed (FBI)

15.4 Defensive Recommendations for Backup Infrastructure

1. **Isolate backup management networks** from application servers
2. **Require MFA** for all Acronis Cloud Console and S3 access
3. **Enable immutable backups** (Acronis immutable storage, S3 Object Lock)
4. **Patch CVE-2026-87886** (cPanel plugin 1.9.3.1021+, Plesk 1.8.11.638+)
5. **Monitor for T1490** indicators (vssadmin, wbadmin, bcdedit, Acronis service stops)
6. **Maintain air-gapped backup copies** physically disconnected from networks

References

- [1] Mallory.ai, “SIDEYE Malware Analysis,” 2026.
<https://mallory.ai/malware/01a0db4c-9c01-79a4-9f47-d4c5b13b51b5>
- [2] SOCPrime, “ShinyHunters Exploits Oracle PeopleSoft in Education,” 2026.
<https://socprime.com/active-threats/shinyhunters-targets-education-sector-with-oracle-p>
- [3] The Hacker News, “ShinyHunters Exploits Oracle PeopleSoft Zero-Day (CVE-2026-35273) to Breach Universities,” June 2026.
<https://thehackernews.com/2026/06/shinyhunters-exploits-oracle-peoplesoft.html>
- [4] Rapid7, “Active Exploitation of Oracle PeopleSoft Zero-Day (CVE-2026-35273),” June 2026.
<https://www.rapid7.com/blog/post/etr-active-exploitation-of-oracle-peoplesoft-zero-day->
- [5] SecurityWeek, “Google Confirms Exploitation of Oracle PeopleSoft Zero-Day by ShinyHunters,” June 2026.
<https://www.securityweek.com/google-confirms-exploitation-of-oracle-peoplesoft-zero-day>
- [6] BleepingComputer, “ShinyHunters claims FBI hack, data theft in PeopleSoft zero-day breach,” September 2026.
<https://www.bleepingcomputer.com/news/security/shinyhunters-claims-fbi-hack-data-theft->
- [7] The Hacker News, “ShinyHunters Claims FBI Breach, Says It Stole Data on Agents and Job Applicants,” September 2026.
<https://thehackernews.com/2026/09/shinyhunters-claims-fbi-breach-says-it.html>
- [8] Help Net Security, “FBI job portals remain offline after ShinyHunters claims breach via PeopleSoft zero-day,” September 28, 2026.
<https://www.helpnetsecurity.com/2026/09/28/fbi-job-portals-offline-shinyhunters-breach/>
- [9] SOCPrime, “CVE-2026-87886: Acronis Backup Plugin Flaw Exploited,” September 2026.
<https://socprime.com/blog/cve-2026-87886-acronis-backu-plugin-flaw-exploited/>
- [10] Aviatrix, “ShinyHunters Oracle PeopleSoft CVE-2026-35273 WAF Bypass Attack Analysis,” 2026.
<https://aviatrix.ai/threat-research-center/shinyhunters-oracle-peoplesoft-cve-2026-3527>
- [11] Google Cloud / Mandiant, “ShinyHunters Renewed Mass Exploitation Campaign Targeting Oracle PeopleSoft,” 2026.
<https://cloud.google.com/blog/topics/threat-intelligence/shinyhunters-renewed-mass-exploitation-campaign-targeting-oracle-peoplesoft>
- [12] CyberInsider, “ShinyHunters claims FBI breach,” September 2026.
<https://cyberinsider.com/shinyhunters-claims-fbi-breach/>
- [13] Push Security, “How three techniques are behind ShinyHunters’ 2026 campaigns,” 2026.
<https://pushsecurity.com/blog/analyzing-the-instructure-breach>
- [14] Acronis, “Cyberthreats Update, August 2026,” 2026.
<https://www.acronis.com/en/tru/posts/acronis-cyberthreats-update-august-2026/>
- [15] MITRE ATT&CK, “T1490 — Inhibit System Recovery.”
<https://attack.mitre.org/techniques/T1490/>

A Methodology

All analysis was performed using the following data sources and tools:

- **VirusTotal Graph Exports:** Shiny_Hunters_PeopleSoftZeroDay.json (1,805 nodes, 2,186 links), EntireGraph.json (458 nodes, 497 links)
- **JSP Webshell Identifiers:** 60 SHA-256 hashes
- **Domain Indicators:** subset.csv (20 domains)
- **Sandbox Reports:** Yomi Hunter and VirusTotal behavioral analysis of LA.exe
- **WHOIS/RDAP:** IPWhois library for IP RDAP, python-whois for domain WHOIS
- **DNS:** dnspython for reverse DNS, socket library fallback

Reproducibility scripts in `scripts/` directory:

1. `01_extract_graph_data.py` — Graph data extraction and structuring
2. `02_whois_rdns_analysis.py` — WHOIS, RDAP, and rDNS enrichment
3. `03_infrastructure_mapper.py` — Infrastructure tier mapping
4. `04_domain_timeline_analysis.py` — Domain registration timeline and phase classification
5. `05_payload_capability_analysis.py` — SIDEYE, LA.exe, MeshAgent, and D4M assessment

B Diagram Index

Fig.	File	Description
1	<code>04_webshell_to_payload.png</code>	JSP webshell to payload delivery chain
2	<code>01_attack_chain_overview.png</code>	High-level attack chain overview
3	<code>02_infrastructure_resolution.png</code>	DNS resolution chains
4	<code>03_vpn_anonymization_layer.png</code>	VPN and anonymization infrastructure
5	<code>05_dga_domain_patterns.png</code>	DGA domain patterns
6	<code>06_provider_infrastructure_map.png</code>	Complete provider infrastructure map
7	<code>07_government_cloud_attack_path.png</code>	Government-themed domains and cloud abuse
8	<code>08_campaign_timeline.png</code>	Campaign lifecycle timeline
9	<code>09_attack_sequence_flow.png</code>	Attack sequence domain-to-domain flow
10	<code>10_sideeye_capability_map.png</code>	SIDEYE backdoor capability map
11	<code>11_backup_destruction_attack_tree.png</code>	D4M backup destruction attack tree
12	<code>12_fbi_breach_lateral_movement.png</code>	FBI breach lateral movement chain
13	<code>13_acronis_cve_timeline_overlap.png</code>	CVE-2026-87886 timeline overlap